

Azure Zero Trust Architecture Configuration Procedure

For a Simulated Cloud-Based Electronic Health Record System

Project: A Management Framework for Implementing Zero Trust Architecture in Cloud-Based EHR Systems

Purpose: This document gives the full practical Azure procedure for configuring a simulated healthcare organisation, mock EHR cloud storage, Microsoft Entra ID users and groups, role-based access control, Conditional Access MFA, risk-based policies, monitoring, audit evidence and cost protection. The implementation is for academic demonstration only and must not use real patient data.

Item	Configuration
Cloud platform	Microsoft Azure portal
Identity platform	Microsoft Entra ID
Licence assumption	Microsoft Entra ID P2 activated
Simulated organisation name	MediTrust Health Cloud
Mock EHR resource group	rg-meditrust-ehr-zta
Storage account example	meditrustztestorage
Data type	Dummy/non-real patient record files only

Implementation Checklist

Stage	Main evidence to capture
A. Prepare Azure environment	Azure portal login, P2 licence/status, screenshot privacy precautions
B. Simulated healthcare organisation	Renamed Microsoft Entra directory
C. Mock users	Doctor, nurse, records admin, IT security admin, cloud admin, vendor and auditor
D. Security groups	Assigned security groups with descriptions and members
E. Mock cloud EHR resource	Resource group and Azure Storage account
F. Private EHR containers	patient-records, admin-records and audit-evidence containers
G. Dummy files	Non-real patient record files uploaded for demonstration
H. Storage security	Anonymous access disabled, secure transfer enabled, TLS configured
I. Azure RBAC	Least privilege role assignments by group
J. Conditional Access	MFA, risk-based access and admin MFA policies
K. PIM	Optional just-in-time admin control if available
L. Monitoring	Sign-in logs, audit logs, activity log and diagnostic settings
M. Testing and reporting	Doctor/nurse/vendor access tests, evidence table and screenshots

A. Prepare the Azure Environment

1. Sign in to Azure

1. Open a browser and go to <https://portal.azure.com>.
2. Sign in with the Microsoft account or school account used for the Azure free account.
3. Confirm that the Azure portal opens successfully and that Microsoft Entra ID is available from the search bar.

Screenshot evidence: Capture the Azure portal home page or Microsoft Entra ID overview. Blur or crop your email address, tenant ID, subscription ID and any private details before placing screenshots in your report.

2. Confirm Microsoft Entra ID P2 Licence

4. Go to Microsoft Entra ID → Overview.
5. Check the licence/status area to confirm that P2 features are active.
6. If it still shows Microsoft Entra ID Free, go to Microsoft Entra ID → Licences → All products and confirm that the P2 licence is assigned to your admin account.
7. Use this evidence to justify the use of Conditional Access, Identity Protection and risk-based access policies in your project.

Screenshot evidence: Take a screenshot of the Microsoft Entra ID overview or licensing page showing the licence status.

B. Set Up the Simulated Healthcare Organisation

3. Rename the Directory

8. Go to Microsoft Entra ID → Properties.
9. Change the directory name from Default Directory to MediTrust Health Cloud.
10. Click Save.
11. Return to Overview and confirm that the new name appears.

Why this matters: This makes the project evidence look like a simulated healthcare organisation rather than a default personal Azure directory.

C. Create Mock Healthcare Users

4. Create Users in Microsoft Entra ID

12. Go to Microsoft Entra ID → Users → New user → Create new user.
13. Create each mock user one after another.
14. When the Directory roles page appears, leave it blank for Doctor, Nurse, Records Admin, Vendor and Auditor.
Directory roles are for Azure administrative roles, not clinical roles.
15. Save the temporary password for each user only for testing, then keep it securely.

Display name	Username	Project meaning
Doctor User	doctor01	Clinical user who requires access to patient records
Nurse User	nurse01	Clinical user with limited patient-care access
Records Admin User	recordsadmin01	Administrative user for non-clinical records
IT Security Admin User	itsecurityadmin01	Security monitoring and incident response user
Cloud Admin User	cloudadmin01	Cloud resource management user
Vendor User	vendor01	Third-party vendor with restricted technical access
Auditor User	auditor01	Compliance/audit user for reviewing logs and evidence

Screenshot evidence: Capture the Users list after all mock users have been created.

D. Create Security Groups

5. Create Assigned Security Groups

16. Go to Microsoft Entra ID → Groups → New group.
17. Set Group type to Security.
18. Set Membership type to Assigned.
19. Enter the group name and description, then add the correct mock user as a member.
20. Repeat the process until all project groups have been created.

Group name	Group description	Member
EHR-Doctors	Security group for doctors who require authorised access to cloud-based EHR patient records.	doctor01
EHR-Nurses	Security group for nurses with limited access to approved patient-care EHR records.	nurse01
EHR-Records-Admins	Security group for records and administrative staff who manage non-clinical EHR information.	recordsadmin01
EHR-IT-Security	Security group for IT security staff responsible for monitoring, access review and incident response.	itsecurityadmin01
EHR-Cloud-Admins	Security group for cloud administrators responsible for managing Azure EHR cloud resources.	cloudadmin01
EHR-Vendors	Security group for third-party vendors with restricted and monitored access to approved technical resources.	vendor01
EHR-Auditors	Security group for auditors who review access logs, compliance evidence and security reports.	auditor01

Screenshot evidence: Capture the Groups list and one group details page showing its members.

E. Create the Mock Cloud-Based EHR Resource Environment

6. Create Resource Group

21. In the Azure search bar, type Resource groups and open it.
22. Click Create.
23. Enter the resource group name: rg-meditrust-ehr-zta.
24. Choose a region close to your location or a low-cost available region.
25. Click Review + create, then Create.

Field	Entry
Resource group name	rg-meditrust-ehr-zta
Region	Nearest or low-cost available Azure region
Purpose	Simulated cloud-based EHR Zero Trust environment

Screenshot evidence: Capture the resource group overview page after creation.

F. Create Storage for Simulated EHR Records

7. Create Azure Storage Account

26. Go to Resource groups → rg-meditrust-ehr-zta.
27. Click Create and search for Storage account.
28. Open Storage account and click Create.
29. Complete the Basics tab using the configuration below.

30. Review the remaining tabs and keep low-cost/basic options unless your supervisor requires advanced configuration.
31. Click Review + create, then Create.

Setting	Recommended value
Storage account name	meditrustztstorage or another globally unique lowercase name
Region	Same region as the resource group
Performance	Standard
Redundancy	Locally-redundant storage where available
Public network access	Enabled only if needed for testing; keep access restricted where possible
Secure transfer	Enabled
Minimum TLS version	TLS 1.2 or higher

Screenshot evidence: Capture the Storage account overview page.

G. Create Private Containers

8. Create EHR Data Containers

32. Open the storage account.
33. Go to Data storage → Containers.
34. Click + Container.
35. Create each container listed below.
36. Set Public access level to Private for each container.

Container name	Public access level	Purpose
patient-records	Private	Simulated clinical records
admin-records	Private	Simulated appointment/billing records
audit-evidence	Private	Simulated audit and compliance files

Screenshot evidence: Capture the Containers page showing the three private containers.

H. Upload Dummy EHR Files

9. Create and Upload Dummy Files

37. Create simple text files on your laptop using Notepad or Microsoft Word saved as .txt files.
38. Use only dummy content. Do not include real patient names, addresses, phone numbers, diagnoses, hospital data or private information.
39. Open the patient-records container.
40. Click Upload and upload the dummy files.
41. Repeat only if you want extra dummy records for your demonstration.

File name	Suggested file content
patient_record_001.txt	Dummy patient record for academic demonstration only. No real patient data is used.
lab_result_001.txt	Dummy laboratory result for academic demonstration only. No real patient data is used.
prescription_001.txt	Dummy prescription record for academic demonstration only. No real patient data is used.

Screenshot evidence: Capture the patient-records container showing the uploaded dummy files.

I. Configure Storage Security Settings

10. Disable Anonymous Access and Enforce Secure Transfer

42. Open the storage account.
43. Go to Settings → Configuration.
44. Set Allow Blob anonymous access to Disabled.
45. Confirm Secure transfer required is Enabled.
46. Confirm Minimum TLS version is TLS 1.2 or higher.
47. Save the configuration if changes were made.

Security setting	Recommended value	Zero Trust meaning
Allow Blob anonymous access	Disabled	Prevents public/anonymous access to EHR-like files
Secure transfer required	Enabled	Ensures encrypted HTTPS communication
Minimum TLS version	TLS 1.2 or higher	Supports secure communication requirements

Screenshot evidence: Capture the storage account configuration/security settings page.

J. Configure Role-Based Access Control

11. Assign Azure RBAC Roles

48. Open the storage account or a specific container.
49. Click Access Control (IAM).
50. Click Add → Add role assignment.
51. Choose the required role, then assign it to the correct security group.
52. Use container-level assignment where available to keep access narrow.
53. Repeat until each group has the required level of access.

Group	Azure role	Recommended scope	Reason
EHR-Doctors	Storage Blob Data Contributor	patient-records container	Doctors may need to read and update simulated patient records.
EHR-Nurses	Storage Blob Data Reader	patient-records container	Nurses get read-only access for patient-care support.
EHR-Records-Admins	Storage Blob Data Reader	admin-records container	Records staff access non-clinical records only.
EHR-Auditors	Reader or Storage Blob Data Reader	audit-evidence container	Auditors review compliance evidence without admin privileges.
EHR-Vendors	No patient-records access	None or restricted technical scope	Vendors must not access patient data in the simulation.
EHR-Cloud-Admins	Contributor or Storage Account Contributor	resource group or storage account	Cloud admin manages infrastructure, not unrestricted patient-data use.
EHR-IT-Security	Reader/Security Reader where available	resource group or monitoring scope	Security user reviews logs and security evidence.

Zero Trust mapping: This section demonstrates least privilege access and group-based access governance. It shows that access is based on identity, role and approved need rather than broad trust.

Screenshot evidence: Capture the IAM role assignments page after assigning roles.

K. Configure Conditional Access MFA

12. Create an Emergency Access Account

54. Before enforcing Conditional Access, create an emergency admin account such as emergency.admin.
55. Do not use the emergency account for normal work.
56. Exclude this account from restrictive Conditional Access policies to avoid locking yourself out.
57. Keep the password secure and store it separately.

Screenshot evidence: Capture the emergency account in the Users list, but do not expose the password or recovery details.

13. Create MFA Policy for EHR Users

58. Go to Microsoft Entra ID → Protection → Conditional Access → Policies → New policy.
59. Name the policy: CA001 - Require MFA for EHR Users.
60. Under Users, include the EHR security groups.
61. Under Exclude, exclude emergency.admin.
62. Under Target resources, select All cloud apps or Microsoft Azure Management for your demonstration.
63. Under Grant, select Require multifactor authentication.
64. Set Enable policy to Report-only first.
65. Create the policy and later switch it to On only after testing.

Policy item	Configuration
Policy name	CA001 - Require MFA for EHR Users
Included users/groups	EHR-Doctors, EHR-Nurses, EHR-Records-Admins, EHR-Vendors, EHR-Auditors, EHR-IT-Security, EHR-Cloud-Admins
Excluded users	emergency.admin
Target resources	All cloud apps or Microsoft Azure Management
Grant control	Require multifactor authentication
Initial state	Report-only

Screenshot evidence: Capture the CA001 policy settings page.

L. Configure Risk-Based Access Policies with P2

14. Block High-Risk Sign-Ins

66. Go to Microsoft Entra ID → Protection → Conditional Access → Policies → New policy.
67. Name the policy: CA002 - Block High Risk Sign-ins.
68. Include EHR user groups.
69. Exclude emergency.admin.
70. Under Conditions, select Sign-in risk and choose High.
71. Under Grant, select Block access.
72. Set Enable policy to Report-only first, then create the policy.

15. Require MFA for Medium-Risk Sign-Ins

73. Create another Conditional Access policy.
74. Name the policy: CA003 - Require MFA for Medium Risk Sign-ins.
75. Include EHR user groups and exclude emergency.admin.
76. Under Conditions, select Sign-in risk and choose Medium.
77. Under Grant, require multifactor authentication.
78. Set Enable policy to Report-only first.

Policy name	Condition	Grant control	Initial state
CA002 - Block High Risk Sign-ins	Sign-in risk: High	Block access	Report-only
CA003 - Require MFA for Medium Risk Sign-ins	Sign-in risk: Medium	Require multifactor authentication	Report-only

Zero Trust mapping: These policies demonstrate continuous verification because the access decision depends on risk signals, not only the first login.

Screenshot evidence: Capture the risk-based Conditional Access policy list and the settings of each policy.

M. Configure Admin MFA Policy

16. Require MFA for Administrative Users

79. Go to Microsoft Entra ID → Protection → Conditional Access → Policies → New policy.
80. Name the policy: CA004 - Require MFA for Admin Roles.
81. Include cloudadmin01 and itsecurityadmin01 or include administrator roles if you assigned directory roles.
82. Exclude emergency.admin.
83. Set Target resources to All cloud apps.
84. Under Grant, require multifactor authentication.
85. Set Enable policy to Report-only first.

Zero Trust mapping: This supports privileged access control because cloud and security administrators represent high-risk accounts.

Screenshot evidence: Capture the CA004 policy settings page.

N. Optional P2 Configuration: Privileged Identity Management

17. Configure PIM for Admin Role Control

86. Go to Microsoft Entra ID → Identity Governance → Privileged Identity Management.
87. Select Microsoft Entra roles or Azure resources depending on the role you want to manage.
88. Make cloudadmin01 and/or itsecurityadmin01 eligible for selected admin roles instead of permanently active, where possible.
89. Configure activation requirements, such as justification and MFA.
90. Capture evidence of eligible assignment or activation settings.

Note: This step is optional. If PIM is not available or too complex within the project timeframe, document it as a recommended production enhancement.

O. Configure Monitoring and Audit Evidence

18. Review Microsoft Entra Sign-In and Audit Logs

91. Go to Microsoft Entra ID → Monitoring → Sign-in logs.
92. Check sign-in events from your test accounts.
93. Go to Microsoft Entra ID → Monitoring → Audit logs.
94. Check events such as user creation, group changes and policy activity.
95. Capture screenshots that show monitoring evidence without exposing sensitive details.

Screenshot evidence: Capture sign-in logs and audit logs after testing mock users.

19. Review Azure Activity Log

96. Go to Monitor → Activity log.
97. Filter by resource group: rg-meditrust-ehr-zta.
98. Review actions such as resource creation, role assignment and storage changes.
99. Use the activity log as evidence of governance and traceability.

Screenshot evidence: Capture the Azure Activity Log filtered by your resource group.

20. Optional Diagnostic Settings

100. Open the storage account.
101. Go to Monitoring → Diagnostic settings → Add diagnostic setting.
102. Select logs such as StorageRead, StorageWrite and StorageDelete if available.
103. Choose a destination such as Log Analytics workspace if you are using it.
104. Be careful because Log Analytics can create costs if too much data is collected.

Screenshot evidence: Capture the diagnostic settings page if you configure it. If not configured, state it as a recommended future enhancement.

P. Test the Configuration

21. Test Doctor Access

105. Open a private/incognito browser window.
106. Sign in as doctor01.
107. Confirm that MFA or authentication registration is triggered where applicable.
108. Try to access the approved EHR storage/container.
109. Confirm that the doctor account does not have full administrative access.

22. Test Nurse Access

110. Open a new private/incognito browser window.
111. Sign in as nurse01.
112. Confirm that the nurse can only read approved records if the reader role has been assigned correctly.
113. Confirm that the nurse cannot manage the storage account or change role assignments.

23. Test Vendor Restriction

114. Open a new private/incognito browser window.
115. Sign in as vendor01.
116. Confirm that the vendor cannot access patient-records.
117. Capture the denied or restricted access message as evidence of least privilege.

Important: Azure role assignments may take several minutes to apply. If access does not work immediately, wait and test again.

Q. Create Cost Protection

24. Create a Budget Alert

118. Go to Cost Management + Billing → Budgets.
119. Click Add or Create budget.
120. Set a small budget threshold such as \$5 or \$10 for the month.
121. Add your email as the alert recipient.
122. Save the budget alert.

Cost warning: Avoid virtual machines, premium databases, paid application services and unnecessary Log Analytics usage unless your supervisor specifically requires them.

R. Evidence Table for the Project Report

Zero Trust component	Azure configuration evidence
Identity governance	Created mock healthcare users in Microsoft Entra ID
Group-based access	Created EHR-Doctors, EHR-Nurses, EHR-Records-Admins, EHR-Vendors, EHR-Auditors, EHR-IT-Security and EHR-Cloud-Admins groups
Least privilege	Assigned limited Azure RBAC roles at storage/container level
MFA	Created Conditional Access MFA policy
Continuous verification	Created sign-in risk policies using Microsoft Entra ID P2
Privileged access management	Created admin MFA policy and optionally configured PIM
Data protection	Created private blob containers, disabled anonymous access and enabled secure transfer
Micro-segmentation	Separated patient records, admin records and audit evidence into different containers
Monitoring	Used Microsoft Entra sign-in logs, audit logs and Azure Activity Log
Governance	Documented screenshots, policies, roles, limitations and implementation workflow

S. Screenshot Checklist

- Microsoft Entra ID overview
- P2 licence/status evidence
- Renamed tenant/directory
- Users list
- Groups list
- One group showing members
- Resource group overview
- Storage account overview
- Private containers
- Dummy patient files
- Storage configuration/security settings
- IAM role assignments
- Conditional Access MFA policy
- Risk-based Conditional Access policies
- Admin MFA policy
- PIM page, if used
- Sign-in logs
- Audit logs
- Azure Activity Log
- Budget alert page

T. Suggested Wording for Chapter Four or Implementation Section

The practical implementation was conducted as a simulated Azure-based Zero Trust configuration for a cloud-hosted EHR environment. Microsoft Entra ID was used for identity governance, security groups were used to represent healthcare roles, Azure RBAC was used to enforce least privilege access, Conditional Access was used to require MFA and risk-based verification, and Azure monitoring tools were used to collect audit evidence. No real patient data was used. Dummy records were uploaded only for academic demonstration. The configuration demonstrates how a healthcare organisation can translate Zero Trust principles into identity governance, access control, continuous verification, data protection, monitoring and governance controls within a cloud-based EHR context.

Common Mistakes to Avoid

- Do not create Doctor, Nurse or Vendor as Directory roles. Use security groups for healthcare roles.
- Do not upload real patient data or real hospital documents.
- Do not leave containers public.
- Do not give all users Contributor or Owner roles.

- Do not turn on restrictive Conditional Access policies before testing in Report-only mode.
- Do not forget to exclude an emergency admin account from blocking policies.
- Do not expose your tenant ID, email address, subscription ID, passwords or keys in screenshots.
- Do not use expensive Azure services if the project can be demonstrated with Entra ID, Storage, RBAC and logs.

Official Microsoft Documentation Used for the Procedure

- Microsoft Learn. Microsoft Entra Conditional Access: Zero Trust policy engine. <https://learn.microsoft.com/en-us/entra/identity/conditional-access/overview>
- Microsoft Learn. Build Conditional Access policies in Microsoft Entra. <https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-policies>
- Microsoft Learn. Configure Microsoft Entra ID Protection risk policies. <https://learn.microsoft.com/en-us/entra/id-protection/howto-identity-protection-configure-risk-policies>
- Microsoft Learn. Require multifactor authentication for elevated sign-in risk. <https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-risk-based-sign-in>
- Microsoft Learn. Assign an Azure role for access to blob data. <https://learn.microsoft.com/en-us/azure/storage/blobs/assign-azure-role-data-access>
- Microsoft Learn. Authorize access to blob data in the Azure portal. <https://learn.microsoft.com/en-us/azure/storage/blobs/authorize-data-operations-portal>
- Microsoft Learn. Activity log in Azure Monitor. <https://learn.microsoft.com/en-us/azure/azure-monitor/platform/activity-log>
- Microsoft Learn. Diagnostic settings in Azure Monitor. <https://learn.microsoft.com/en-us/azure/azure-monitor/platform/diagnostic-settings>
- Microsoft Learn. Use cost alerts to monitor usage and spending. <https://learn.microsoft.com/en-us/azure/cost-management-billing/costs/cost-mgt-alerts-monitor-usage-spending>